Privacy Cash - Privacy Cash USDC SDK Audit Report

Version 1.1

Zigtur

December 8, 2025

Privacy Cash - Privacy Cash USDC SDK - Audit Report

Zigtur

December 8, 2025

Prepared by: Zigtur

Table of Contents

- Table of Contents
- Introduction
  - Disclaimer
  - About Zigtur
  - About Privacy Cash
- Security Assessment Summary
  - Deployment chains
  - Scope
  - Risk Classification
- Issues
  - INFO-01 - Package name is not easily understandable
  - INFO-02 - Incorrect variable use in log
  - INFO-03 - Hardcoded recipient in depositSPL file

Introduction

Disclaimer

A smart contract security review cannot guarantee the complete absence of vulnerabilities. This effort, bound by time, resources, and expertise, aims to identify as many security issues as possible. However, there is no assurance of 100% security post-review, nor is there a guarantee that the review will uncover all potential problems in the smart contracts. It is highly recommended to conduct subsequent security reviews, implement bug bounty programs, and perform on-chain monitoring.

About Zigtur

Zigtur is an independent blockchain security researcher dedicated to enhancing the security of the blockchain ecosystem. With a history of identifying numerous security vulnerabilities across various protocols in public audit contests and private audits, **Zigtur** strives to contribute to the safety and reliability of blockchain projects through meticulous security research and reviews. Explore previous work here or reach out on X @zigtur.

About Privacy Cash

PrivacyCash is a decentralized protocol for secure and anonymous transactions built on Solana.

Using zero-knowledge proofs, it lets users deposit assets and withdraw them to different addresses, breaking the link between sender and receiver. By combining advanced cryptography with decentralized infrastructure, PrivacyCash restores financial privacy and freedom on public blockchains.

Security Assessment Summary

Review commit hash - PR 53 - commit b55cbf757c9f59a944c48d0f72fc035796b4832a

Fixes review commit hash - PR 53 - commit f6f5cee862fb3b1094b1afce0a0f950737bddc43

Deployment chains

- Solana

Scope

The following code is in scope of the review:

- src/depositSPL.ts
- src/withdrawSPL.ts

Note: Issues reported and acknowledged in the first SDK review will not be reported in this report. Multiple privacy leak vectors were previously reported, this impact is out of scope.

Risk Classification

	Impact: High	**Impact:** Medium	**Impact:** Low
Likelihood: High	High	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

Issues

INFO-01 - Package name is not easily understandable

Scope:

- package.json#L2

Description

The package is named `devpcsdk`. This name is not easily understandable.

```
{
  "name": "devpcsdk",
```

Recommendation

Fix the package name.

Privacy Cash

Fixed in PR53 - commit 35e2ade.

Zigtur

Fixed.

INFO-02 - Incorrect variable use in log

Scope:

- depositSPL.ts#L134-L140

Description

`logger.debug` is called with `balance` instead of `solBalance`.

```
// Check SOL balance
const solBalance = await connection.getBalance(publicKey);
logger.debug(`SOL Wallet balance: ${balance / 1e9} SOL`);

if (solBalance / 1e9 < 0.01) {
    throw new Error(`Need at least 0.01 SOL for Solana fees.`);
}
```

Recommendation

Use `solBalance` instead of `balance`.

Privacy Cash

Fixed in PR53 - commit f6f5cee.

Zigtur

Fixed.

INFO-03 - Hardcoded recipient in depositSPL file

Scope:

- src/depositSPL.ts

Description

The `recipient` address is hardcoded to `AWexibGxNFKTa1b5R5MN4PJr9HWnWRwf8EW9g8cLx3dM`. This address is used to derive the `recipient_ata` which is included in the `ExtData` of the deposit transaction. While `recipient` is not used for fund transfer in deposits, using a static address creates a constant value in the `ExtData` for all deposits.

```
let recipient = new PublicKey('AWexibGxNFKTa1b5R5MN4PJr9HWnWRwf8EW9g8cLx3dM')
```

Recommendation

Verify if this placeholder is intended.

Privacy Cash

Acknowledged. Recipient in `deposit()` is just passed up to the solana program, but never used.

Zigtur

Acknowledged.